

Module 12 Assignment:
Incident Response Simulation & SIEM
JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

Incident Response Report

SIEM Alert: Multiple Failed Login Attempts Followed by Successful Privileged Login

Date of Alert: 2025-10-22 13:45:12

Host: finance-server-03

User: user15

Source IP: 198.51.100.42

The SIEM alert shows multiple failed login attempts followed by a successful privileged login to finance-server-03 using the account *user15*. This pattern is consistent with a **potential credential-based attack**, including brute-force attempts, password spraying, or credential compromise. The detection and analysis phase of the incident response lifecycle emphasizes validating suspicious activity before escalating it as an incident (Sawant, n.d.).

Important Note on the Source IP

The source IP address **198.51.100.42** falls within the **TEST-NET-2** documentation range (Cotton, Vegoda, & Bonica, 2010) . This IP block is reserved for examples and **cannot originate real network traffic**. Its presence in the log indicates one of the following:

- **A SIEM or log-ingest misconfiguration**, where placeholder IPs are being substituted
- **A normalization or parsing error** in the logging pipeline
- **Synthetic or masked data** from a training or demo environment
- **A false positive** generated by incomplete or malformed logs

Because this IP cannot exist on the public internet, the alert may not represent a real external authentication attempt. This introduces uncertainty and highlights a potential **monitoring gap**, which is itself a risk factor in the detection and analysis phase.

Initial Verification: Before classifying the incident, the analyst must determine:

- **Who is user15?**
- **Was the user attempting to log in at the time of the alert?**

This step is essential because the environment's security maturity is unknown, and the legitimacy of the login directly affects the risk assessment.

Potential Risks: Even with the questionable source IP, the successful privileged login still warrants investigation. Potential risks include:

- Unauthorized privileged access
- Exposure or modification of financial or sensitive data
- Lateral movement
- Privilege escalation
- Data deletion or corruption
- Persistence mechanisms
- Operational disruption
- Regulatory implications

The combination of a privileged login and unreliable log source data increases uncertainty and complicates detection, which elevates the overall risk.

Immediate Containment Steps

Containment begins with **identity verification**, followed by securing the account and preserving evidence — aligning with the containment phase of the incident response lifecycle (Sawant, n.d.).

Step 1: Validate the Account Owner

- Identify who user15 is
- Contact the user directly
- Ask whether they attempted to log in
- Document their response

Step 2: Secure the Account

- Disable or lock the account
- Terminate active sessions
- Require a password reset
- Verify identity before re-enabling

Step 3: Preserve Evidence

- Export authentication logs
- Preserve SIEM event details
- Capture relevant system logs

Step 4: Contain the Source

Even though the IP is non-routable, containment still includes:

- Reviewing firewall and SIEM configurations
- Verifying whether other logs contain placeholder IPs
- Ensuring no real external traffic is being masked

Step 5: Assess the Host

- Review recent activity on finance-server-03

- Look for unusual processes or privilege changes

Eradication and Recovery Actions

Eradication and recovery focus on removing the root cause and restoring systems securely, consistent with the later phases of the incident response lifecycle (Sawant, n.d.).

Eradication

- Reset the password for user15
- Reset passwords for any privileged accounts accessed
- Remove unauthorized accounts, scheduled tasks, or services
- Conduct malware and integrity scans
- Review logs for lateral movement

Recovery

- Re-enable user15 only after identity verification
- Validate system integrity
- Compare system state to known baselines
- Restore finance-server-03 to production only after confirming:
 - No persistence mechanisms
 - No unauthorized access
 - No configuration changes
- Increase monitoring temporarily

Post-Incident Improvements

Post-incident review is essential for strengthening future response and improving detection capabilities (Sawant, n.d.). Because the scenario provides no information about existing controls, improvements should focus on reducing uncertainty and closing common gaps.

- 1. Verify and Implement MFA**
- 2. Establish or Review Account Lockout Policies**
- 3. Strengthen Monitoring and Alerting***
- 4. Formalize Incident Response Procedures**
- 5. Identify and Segment All Service Accounts**

* This includes verifying that **real IP addresses** are being captured and that no placeholder or synthetic values are being substituted.

CONCLUSION

This incident demonstrates how even a small authentication anomaly can reveal deeper issues in monitoring, governance, and detection. A non-routable source IP in a SIEM alert is not just a technical oddity — it signals a potential **visibility gap**, which undermines the organization’s ability to detect real threats. As emphasized in the course content, SIEM provides the “alarm,” but the organization must ensure that the alarm reflects accurate, trustworthy data (Sawant, n.d.).

Unknown controls, undocumented account types, and unreliable log sources all increase uncertainty and slow response. Strengthening identity governance, improving monitoring accuracy, and closing service-account gaps directly reduce the likelihood that a credential-based attack or lateral movement attempt will go undetected. Each incident, even one rooted in log anomalies, is an opportunity to refine processes, validate assumptions, and improve readiness across the entire incident response lifecycle.

REFERENCES

- Cotton, M., Vegoda, L., & Bonica, R. (2010). Special use IPv4 addresses (RFC 5735). Internet Engineering Task Force. <https://datatracker.ietf.org/doc/html/rfc5735>
- Sawant, A. (n.d.). Module 12: Incident response and SIEM [Coursera course content]. Northeastern University.
- National Institute of Standards and Technology. (2012). Computer security incident handling guide (NIST Special Publication 800-61 Revision 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>
- Splunk Inc. (n.d.). What is Splunk? https://www.splunk.com/en_us/data-insider/what-is-splunk.html

AI Use Statement

This report was developed using my own analysis, prior research from earlier modules, and professional experience, with support from Microsoft Copilot. Copilot assisted with iteratively refining the structure of the paper, improving clarity and flow. Copilot also helped format APA references and ensure alignment with the assignment rubric. All AI-generated suggestions were reviewed, edited, and validated by me to ensure accuracy, relevance, and consistency with course materials. I am fully responsible for the final content and for ensuring that all AI use complies with Northeastern University’s Academic Integrity and Use of AI policy.